



АКАДЕМИЯ
КОДЕБАЙ

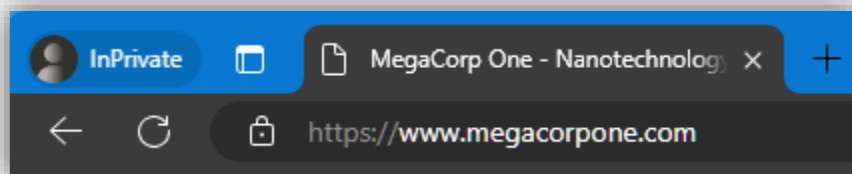
ПРОФЕССИЯ ПЕНТЕСТЕР

Всех приветствую!

В этом разделе мы выйдем за рамки пассивного сбора информации и изучим методы, предполагающие прямое взаимодействие с целевыми службами. Мы рассмотрим некоторые базовые методы, но следует помнить, что существует бесчисленное множество служб, которые могут быть потенциально уязвимыми в реальных условиях. К ним относится, например, Active Directory, которую мы более подробно рассмотрим в отдельном уроке. В этом разделе мы рассмотрим некоторые из наиболее распространенных методов активного сбора информации, включая сканирование портов и эnumерацию DNS, SMB, NFS, SMTP и SNMP.

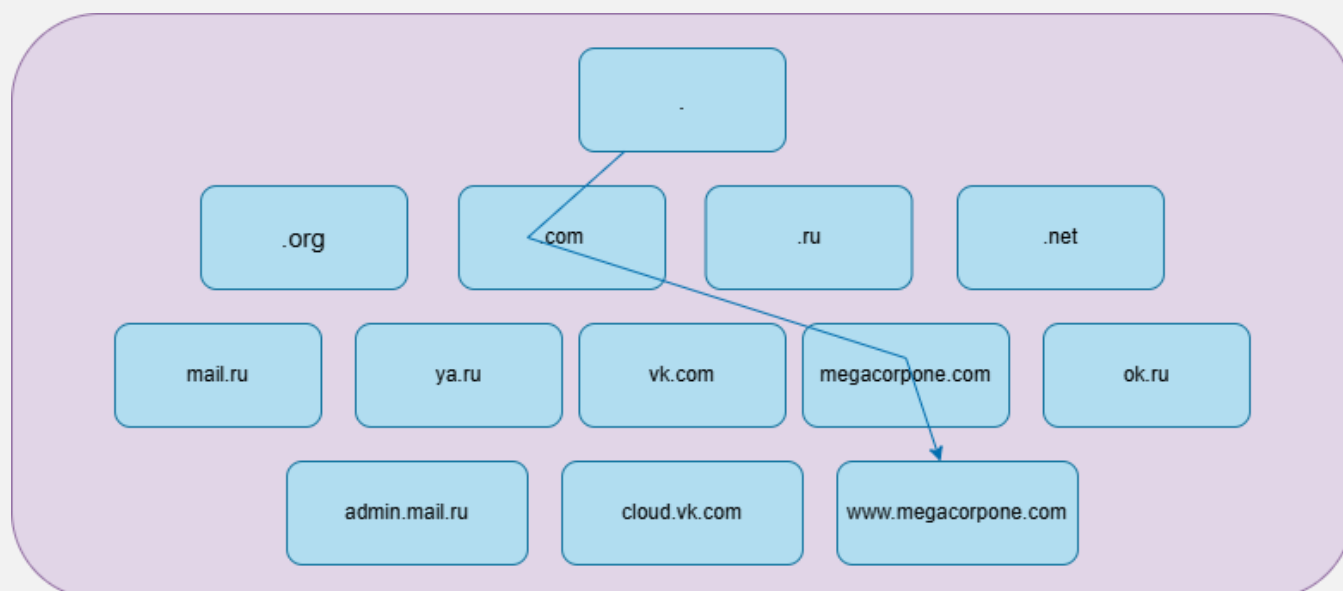
Система доменных имен (DNS) является одной из наиболее важных систем в Интернете и представляет собой распределенную базу данных, отвечающую за преобразование удобных для пользователя доменных имен в IP-адреса. Этому способствует иерархическая структура, разделенная на несколько зон, начиная с корневой зоны верхнего уровня.

Давайте подробнее рассмотрим процесс и серверы, участвующие в имени хоста, такого как `www.megacorpone.com`. Процесс начинается, когда имя хоста вводится в браузер или другое приложение.



Браузер передает имя хоста DNS-клиенту операционной системы, а операционная система затем направляет запрос на внешний DNS-сервер. Этот сервер в цепочке известен как DNS-рекурсор и отвечает за взаимодействие с инфраструктурой DNS и возврат результатов клиенту DNS. DNS-рекурсор обращается к одному из серверов в корневой зоне DNS. В ответ корневой сервер сообщает адрес сервера, отвечающего за зону, содержащую домен верхнего уровня (ДБУ), в данном случае ДБУ `.com`. Как только рекурсор DNS получает адрес DNS-сервера ДБУ, он запрашивает у него адрес авторитетного сервера имен для домена `megacorpone.com`. Авторитетный сервер имен является заключительным этапом процесса

поиска DNS и содержит записи DNS в локальной базе данных, известной как файл зоны. Обычно он содержит две зоны для каждого домена: зону прямого поиска, которая используется для поиска IP-адреса определенного имени хоста, и зону обратного поиска (если она настроена администратором), которая используется для поиска имени хоста определенного IP-адреса.



Как только DNS рекурсор предоставляет DNS-клиенту IP-адрес для `www.megacorpone.com`, браузер может связаться с нужным веб-сервером по его IP-адресу и загрузить веб-страницу. Для повышения производительности и надежности DNS используется кэширование DNS для хранения локальных копий записей DNS на различных этапах процесса поиска. Именно по этой причине некоторые современные приложения, такие как веб-браузеры, хранят отдельный кэш DNS. Кроме того, локальный DNS-клиент операционной системы также ведет свой собственный DNS-кэш вместе с каждым из DNS-серверов в процессе поиска. Владельцы доменов также могут контролировать, как долго сервер или клиент кэширует запись DNS, с помощью поля Time To Live (TTL) в записи DNS.

Взаимодействие с сервером DNS

Каждый домен может использовать различные типы записей DNS. Некоторые из наиболее распространенных типов DNS включают:

- **NS** - Записи серверов имен содержат имена авторитетных серверов, на которых размещены записи DNS для домена.
- **A** - Также известная как запись хоста, содержит IP-адрес имени хоста (например, www.megacorpone.com).
- **MX** - Записи Mail Exchange содержат имена серверов, отвечающих за обработку электронной почты для домена. Домен может содержать несколько записей MX.
- **PTR** - записи указателей используются в зонах обратного поиска и применяются для поиска записей, связанных с IP-адресом.
- **CNAME** - записи канонических имен используются для создания псевдонимов для других записей хостов.
- **TXT** - Текстовые записи могут содержать любые произвольные данные и могут использоваться для различных целей, например, для проверки владения доменом (**P.S. Вы как этичный хакер перед началом тестирования на проникновение можете просить своего клиента внести новую TXT-запись для проверки того, что именно он владеет WEB-ресурсом**).

Из-за большого количества информации, содержащейся в DNS, DNS часто становится выгодной целью для активного сбора информации.

Чтобы продемонстрировать это, мы воспользуемся утилитой host для поиска IP-адреса www.megacorpone.com:

```
(kali㉿kali)-[~]  
$ host www.megacorpone.com  
www.megacorpone.com has address 149.56.244.87  
  
(kali㉿kali)-[~]  
$
```

По умолчанию команда host ищет запись A, но мы можем запросить и другие поля, например, MX или TXT. Для этого мы можем использовать опцию -t, чтобы указать тип записи, которую мы ищем:

```
(kali㉿kali)-[~]  
$ host -t mx megacorpone.com  
megacorpone.com mail is handled by 10 fb.mail.gandi.net.  
megacorpone.com mail is handled by 60 mail2.megacorpone.com.  
megacorpone.com mail is handled by 20 spool.mail.gandi.net.  
megacorpone.com mail is handled by 50 mail.megacorpone.com.  
  
(kali㉿kali)-[~]  
$ host -t txt megacorpone.com  
megacorpone.com descriptive text "Try Harder"  
megacorpone.com descriptive text "google-site-verification=U7B_b0HNeBtY4qYGQZ  
NsEYXfCJ32hMNV3GtC0wWq5pA"
```

Теперь, когда у нас есть некоторые начальные данные о домене megacorpone.com, мы можем продолжить использовать дополнительные DNS-запросы, чтобы обнаружить больше имен хостов и IP-адресов, принадлежащих тому же домену. Например, мы знаем, что в домене есть веб-сервер с именем хоста "www.megacorpone.com". Давайте еще раз выполним команду host к этому имени хоста:

```
(kali㉿kali)-[~]  
$ host www.megacorpone.com  
www.megacorpone.com has address 149.56.244.87  
  
(kali㉿kali)-[~]  
$
```

Теперь давайте посмотрим, есть ли у megacorpone.com сервер с именем хоста "cyberteam". Обратите внимание на разницу между результатами запроса:

```
(kali㉿kali)-[~]  
$ host www.megacorpone.com  
www.megacorpone.com has address 149.56.244.87  
  
(kali㉿kali)-[~]  
$ host cyberteam.megacorpone.com  
Host cyberteam.megacorpone.com not found: 3(NXDOMAIN)
```

В первом примере мы запросили действительное имя хоста и получили ответ с IP-адресом. Во втором примере возвращается ошибка (NXDOMAIN), которая указывает на то, что публичная запись DNS для этого имени хоста не существует. Теперь, когда мы поняли, как искать действительные имена хостов, мы можем автоматизировать наши действия.

Прямой поиск перебором

Перебор – это метод проб и ошибок, который направлен на поиск достоверной информации, включая каталоги на веб-сервере, комбинации имени пользователя и пароля, или, в данном случае, достоверные записи DNS. Используя список слов, содержащий имена хостов, мы можем попытаться угадать записи DNS и проверить ответ на наличие действительных имен хостов. В предыдущих примерах мы использовали прямой поиск, который запрашивает IP-адрес имени хоста, чтобы запросить как действительное, так и недействительное имя хоста.

Мы можем автоматизировать DNS-поиск с помощью команды `host` в Bash.

Сначала создадим список возможных имен хостов:

```
(kali㉿kali)-[~]  
$ cat > list.txt  
www  
ftp  
mail  
owa  
proxy  
router  
^C
```

Далее мы можем использовать однострочную команду Bash для перебора:

```
kali@kali:~$ for ip in $(cat list.txt); do host $ip.megacorpone.com; done
```

```
(kali㉿kali)-[~]  
$ for ip in $(cat list.txt); do host $ip.megacorpone.com; done  
www.megacorpone.com has address 149.56.244.87  
Host ftp.megacorpone.com not found: 3(NXDOMAIN)  
mail.megacorpone.com has address 51.222.169.212  
Host owa.megacorpone.com not found: 3(NXDOMAIN)  
Host proxy.megacorpone.com not found: 3(NXDOMAIN)  
router.megacorpone.com has address 51.222.169.214
```

С помощью этого простого списка слов мы обнаружили записи для "www", "mail" и "router". Однако имена хостов "ftp", "owa" и "proxy" не были найдены.

Обратный перебор

Наш прямой перебор DNS выявил набор разрозненных IP-адресов в том же приблизительном диапазоне (51.222.169.X). Если DNS-администратор megacorpone.com настроил записи [PTR](#) для домена, мы могли бы просканировать приблизительный диапазон обратным поиском, чтобы запросить имя хоста для каждого IP. Используем цикл для сканирования IP-адресов с 51.222.169.200 по 51.222.169.255. Мы отфильтруем недействительные результаты и покажем только те записи, которые не содержат "not found" (с помощью grep -v):

```
kali@kali:~$ for ip in $(seq 200 255); do host 51.222.169.$ip; done | grep -v "not found" | grep "megacorpone"
```

```
(kali@kali)-[~]  
$ for ip in $(seq 200 255); do host 51.222.169.$ip; done | grep -v "not found" | grep "megacorpone"  
208.169.222.51.in-addr.arpa domain name pointer admin.megacorpone.com.  
209.169.222.51.in-addr.arpa domain name pointer beta.megacorpone.com.  
210.169.222.51.in-addr.arpa domain name pointer fs1.megacorpone.com.  
211.169.222.51.in-addr.arpa domain name pointer intranet.megacorpone.com.  
212.169.222.51.in-addr.arpa domain name pointer mail.megacorpone.com.  
213.169.222.51.in-addr.arpa domain name pointer mail2.megacorpone.com.  
214.169.222.51.in-addr.arpa domain name pointer router.megacorpone.com.  
215.169.222.51.in-addr.arpa domain name pointer siem.megacorpone.com.  
216.169.222.51.in-addr.arpa domain name pointer snmp.megacorpone.com.  
217.169.222.51.in-addr.arpa domain name pointer syslog.megacorpone.com.  
218.169.222.51.in-addr.arpa domain name pointer support.megacorpone.com.  
219.169.222.51.in-addr.arpa domain name pointer test.megacorpone.com.  
220.169.222.51.in-addr.arpa domain name pointer vpn.megacorpone.com.
```

Нам удалось успешно определить ряд IP-адресов на действительные узлы с помощью обратного поиска DNS.

Передача зоны DNS

Передача зоны – это, по сути, репликация базы данных между связанными DNS-серверами, при которой файл зоны копируется с ведущего DNS-сервера на ведомый сервер. Файл зоны содержит список всех имен DNS, настроенных для этой зоны. Передача зоны должна быть разрешена только авторизованным ведомым DNS-серверам, но многие администраторы неправильно конфигурируют свои DNS-серверы, и в таких случаях любой, кто просит копию зоны DNS-сервера, обычно получает ее. Это равносильно тому, чтобы вручить хакеру схему корпоративной сети на блюдечке с голубой каемочкой. Все имена, адреса и функциональные возможности серверов могут стать целым достоянием для посторонних глаз.

Синтаксис команды host для выполнения переноса зоны следующий:

host -l <domain name> <dns server address>

Из нашей раннего использования команды host мы заметили, что некоторые DNS-сервера обслуживают домен megacorpone.com. Давайте попробуем выполнить перенос зоны для ns1 и ns2. Мы будем использовать команду host -l (list zone) для попытки переноса зоны:

```
kali@kali:~$ host -l megacorpone.com ns1.megacorpone.com
```

```
(kali@kali)-[~]  
$ host -l megacorpone.com ns1.megacorpone.com  
Using domain server:  
Name: ns1.megacorpone.com  
Address: 51.79.37.18#53  
Aliases:  
  
Host megacorpone.com not found: 5(REFUSED)  
; Transfer failed.
```

К сожалению, похоже, что первый сервер имен, ns1, не разрешает передачу зон DNS, поэтому наша попытка не удалась. Давайте попробуем выполнить те же действия, используя второй сервер имен, ns2:

```
kali@kali:~$ host -l megacorpone.com ns2.megacorpone.com
```

```
(kali@kali)-[~]  
$ host -l megacorpone.com ns2.megacorpone.com  
Using domain server:  
Name: ns2.megacorpone.com  
Address: 51.222.39.63#53  
Aliases:  
  
megacorpone.com name server ns1.megacorpone.com.  
megacorpone.com name server ns2.megacorpone.com.  
megacorpone.com name server ns3.megacorpone.com.  
admin.megacorpone.com has address 51.222.169.208  
beta.megacorpone.com has address 51.222.169.209  
fs1.megacorpone.com has address 51.222.169.210  
intranet.megacorpone.com has address 51.222.169.211  
mail.megacorpone.com has address 51.222.169.212  
mail2.megacorpone.com has address 51.222.169.213  
ns1.megacorpone.com has address 51.79.37.18  
ns2.megacorpone.com has address 51.222.39.63  
ns3.megacorpone.com has address 66.70.207.180  
router.megacorpone.com has address 51.222.169.214  
siem.megacorpone.com has address 51.222.169.215  
snmp.megacorpone.com has address 51.222.169.216  
support.megacorpone.com has address 51.222.169.218  
syslog.megacorpone.com has address 51.222.169.217
```

Этот сервер позволяет передавать зоны и предоставляет полный дамп файла зоны для домена megacorpone.com, предоставляя удобный список IP-адресов и соответствующих DNS-имен хостов!

DNSRecon

[DNSRecon](#) – это продвинутый, современный скрипт перечисления DNS, написанный на языке Python. Запуск DNSRecon против megacorpone.com с использованием опции -d для указания доменного имени и -t для указания типа перечисления (в данном случае передача зоны) дает следующий результат:

```
kali@kali:~$ dnsrecon -d megacorpone.com -t axfr
```

```
└─$ dnsrecon -d megacorpone.com -t axfr
[*] Checking for Zone Transfer for megacorpone.com name servers
[*] Resolving SOA Record
[+] SOA ns1.megacorpone.com 51.79.37.18
[*] Resolving NS Records
[*] NS Servers found:
[+] NS ns3.megacorpone.com 66.70.207.180
[+] NS ns2.megacorpone.com 51.222.39.63
[+] NS ns1.megacorpone.com 51.79.37.18
[*] Removing any duplicate NS server IP Addresses...
[*]
[*] Trying NS server 51.79.37.18
[+] 51.79.37.18 Has port 53 TCP Open
[-] Zone Transfer Failed (Zone transfer error: REFUSED)
[*]
[*] Trying NS server 51.222.39.63
[+] 51.222.39.63 Has port 53 TCP Open
[+] Zone Transfer was successful!!
[*] NS ns1.megacorpone.com 51.79.37.18
[*] NS ns2.megacorpone.com 51.222.39.63
[*] NS ns3.megacorpone.com 66.70.207.180
[*] TXT Try Harder
[*] TXT google-site-verification=U7B_b0HNeBtY4qYGQZNsEYXfCJ32hMNV3GtC0ww
q5pA
[*] MX @.megacorpone.com fb.mail.gandi.net 217.70.178.217
[*] MX @.megacorpone.com fb.mail.gandi.net 217.70.178.215
[*] MX @.megacorpone.com fb.mail.gandi.net 217.70.178.216
[*] MX @.megacorpone.com spool.mail.gandi.net 217.70.178.1
[*] A admin.megacorpone.com 51.222.169.208
```

Судя по полученным результатам, нам удалось выполнить успешную передачу зоны DNS для домена megacorpone.com. В результате мы получили полный дамп файла зоны для домена. Давайте попробуем перебрать дополнительные имена хостов, используя файл list.txt, который мы создали ранее для прямого поиска. Этот список выглядит следующим образом:

www
ftp
mail
owa
proxy
router

Чтобы начать попытку перебора, мы будем использовать опцию -d для указания имени домена, -D для указания имени файла, содержащего строки поддоменов, и -t для указания типа перебора (в данном случае brt для перебора):

```
kali@kali:~$ dnsrecon -d megacorpone.com -D ~/list.txt -t brt
```

```
(kali@kali)-[~]  
$ dnsrecon -d megacorpone.com -D ~/list.txt -t brt  
[*] Using the dictionary file: /home/kali/list.txt (provided by user)  
[*] brt: Performing host and subdomain brute force against megacorpone.com ...  
[+] A www.megacorpone.com 149.56.244.87  
[+] A mail.megacorpone.com 51.222.169.212  
[+] A router.megacorpone.com 51.222.169.214  
[+] 3 Records Found
```

Наша [брутфорс](#) попытка завершилась, и нам удалось получить несколько имен хостов.

DNSenum

[DNSenum](#) - еще один популярный инструмент перечисления DNS. Чтобы показать другой результат, давайте запустим DNSenum против домена zonetransfer.me (который специально разрешает перенос зон):

```
kali@kali:~$ dnsenum zonetransfer.me
```

```
Mail (MX) Servers:  
-----  
ASPMX5.GOOGLEMAIL.COM.      293      IN      A      142.250.115.27  
ALT1.ASPMX.L.GOOGLE.COM.    293      IN      A      142.250.157.27  
ASPMX2.GOOGLEMAIL.COM.      293      IN      A      142.250.157.27  
ALT2.ASPMX.L.GOOGLE.COM.    293      IN      A      173.194.202.27  
ASPMX4.GOOGLEMAIL.COM.      293      IN      A      142.250.141.27  
ASPMX3.GOOGLEMAIL.COM.      293      IN      A      173.194.202.27  
ASPMX.L.GOOGLE.COM.         256      IN      A      142.251.1.27  
  
Trying Zone Transfers and getting Bind Versions:  
-----  
Trying Zone Transfer for zonetransfer.me on nsztm2.digi.ninja ...  
zonetransfer.me.      7200      IN      SOA      (        
zonetransfer.me.      300       IN      HINFO    "Casio    
zonetransfer.me.      301       IN      TXT      (        
zonetransfer.me.      7200      IN      MX       0        
zonetransfer.me.      7200      IN      MX       10       
zonetransfer.me.      7200      IN      MX       10       
zonetransfer.me.      7200      IN      MX       20       
zonetransfer.me.      7200      IN      MX       20       
zonetransfer.me.      7200      IN      MX       20       
zonetransfer.me.      7200      IN      MX       20
```

Эти инструменты перечисления являются одновременно очень эффективными и простыми. Уделите некоторое время практике, прежде чем продолжать.

Команды, используемые в уроке:

```
kali@kali:~$ host www.megacorpone.com
```

```
kali@kali:~$ for ip in $(cat list.txt); do host $ip.megacorpone.com; done
```

```
kali@kali:~$ for ip in $(seq 200 255); do host 51.222.169.$ip; done | grep -v "not  
found" | grep "megacorpone"
```

```
kali@kali:~$ host -l megacorpone.com ns1.megacorpone.com
```

```
kali@kali:~$ host -l megacorpone.com ns2.megacorpone.com
```

```
kali@kali:~$ dnsrecon -d megacorpone.com -t axfr
```

```
kali@kali:~$ dnsrecon -d megacorpone.com -D ~/list.txt -t brt
```

```
kali@kali:~$ dnsenum zonetransfer.me
```